

Tier 1 SOC Analyst Investigation Runbook

Repeatable alert-to-disposition workflow for authentication, endpoint, network, and phishing alerts

1. Acknowledge & Validate

- Confirm alert time, rule name, affected user/host, source/destination, severity, and data source.
- Verify that underlying events exist and the rule did not fire because of malformed or duplicate data.
- Check whether the asset/user is privileged, business-critical, or associated with sensitive data.

2. Establish Context

- Review recent activity for the user, host, IP, process, domain, or hash.
- Compare to known baseline: normal locations, devices, login methods, approved scanners, administrative tools, and maintenance windows.
- Search for related alerts across the same time window and environment.

3. Scope

Alert type	Minimum scope checks
Authentication	Same source -> other users; same user -> other IPs/devices; failures -> successes; MFA; privilege; post-login activity
Endpoint	Parent/child processes; command line; file/hash; persistence; network; user context; related hosts
Network	Source/destination; DNS; ports; frequency; bytes; related hosts; asset role; known scanner/proxy/CDN context
Phishing	Recipients; sender/domain; URL/attachment; clicks; credential submission; mailbox rules; sign-ins; endpoint execution

4. Decide Disposition

- True Positive - activity is malicious or unauthorized and supported by evidence.
- Benign Positive - target behavior occurred but is authorized/expected.
- False Positive - rule logic or data incorrectly matched non-target behavior.
- Informational - no response action needed, but context is useful.

5. Contain or Escalate

- Contain only within authorized Tier 1 procedures: block indicator, revoke session, disable account, isolate host, or remove malicious mail where approved.
- Escalate when privileged identity, successful compromise, persistence, lateral movement, sensitive data, widespread scope, or high business impact is present.
- Preserve evidence before destructive actions when practical.

6. Document

- Alert ID and detection name
- Timestamp with timezone
- Affected user/asset
- Evidence reviewed
- Key findings
- IOC/behavior list
- ATT&CK; mapping where supported
- Severity and rationale
- Disposition
- Containment action
- Escalation reason
- Next owner / handoff notes

7. Close or Hand Off

- Confirm containment or explain why it was not required.
- Record what was searched and what was not found.
- For false/benign positives, document tuning recommendation if recurrence is likely.
- For escalations, make the handoff independently understandable without requiring the next analyst to repeat basic triage.